

Extracción Forense de WhatsApp en Android

Del dispositivo bloqueado a los archivos de base de datos en tu escritorio: técnicas avanzadas de adquisición forense para Android 11+



Estrategias de Adquisición de Datos

La extracción forense requiere seleccionar la técnica apropiada según el nivel de acceso disponible y los objetivos del análisis. Cada método tiene ventajas específicas y limitaciones que determinan su efectividad en diferentes escenarios.



Lógica (Backup)

Depende de adb backup para extraer datos de aplicaciones. Limitada en Android 12+ debido a restricciones de seguridad mejoradas. No accede a zonas protegidas del sistema ni a datos sensibles almacenados en particiones privilegiadas.



Sistema de Archivos

Copia directa de archivos desde el sistema de almacenamiento. Requiere acceso físico al medio y permisos elevados. Permite recuperar estructura completa de directorios y metadatos asociados.



Física (Root)

Acceso bit a bit o copia completa de particiones protegidas como /data. Nuestra técnica hoy: Extracción quirúrgica vía Root simulando un escenario de compromiso total del dispositivo.

Anatomía de WhatsApp en Android 11+

El cambio introducido por "Scoped Storage" modificó radicalmente las rutas tradicionales de almacenamiento en Android, obligando a los investigadores forenses a actualizar sus técnicas de extracción.

Almacenamiento Público (Media)

Ruta:

`/sdcard/Android/media/com.whatsapp/WhatsApp/`

Contenido accesible:

- Fotografías enviadas y recibidas
- Archivos de audio y notas de voz
- Videos compartidos en conversaciones
- Backups cifrados (.crypt14/.crypt15)

Esta zona es accesible sin privilegios Root mediante herramientas estándar de ADB.

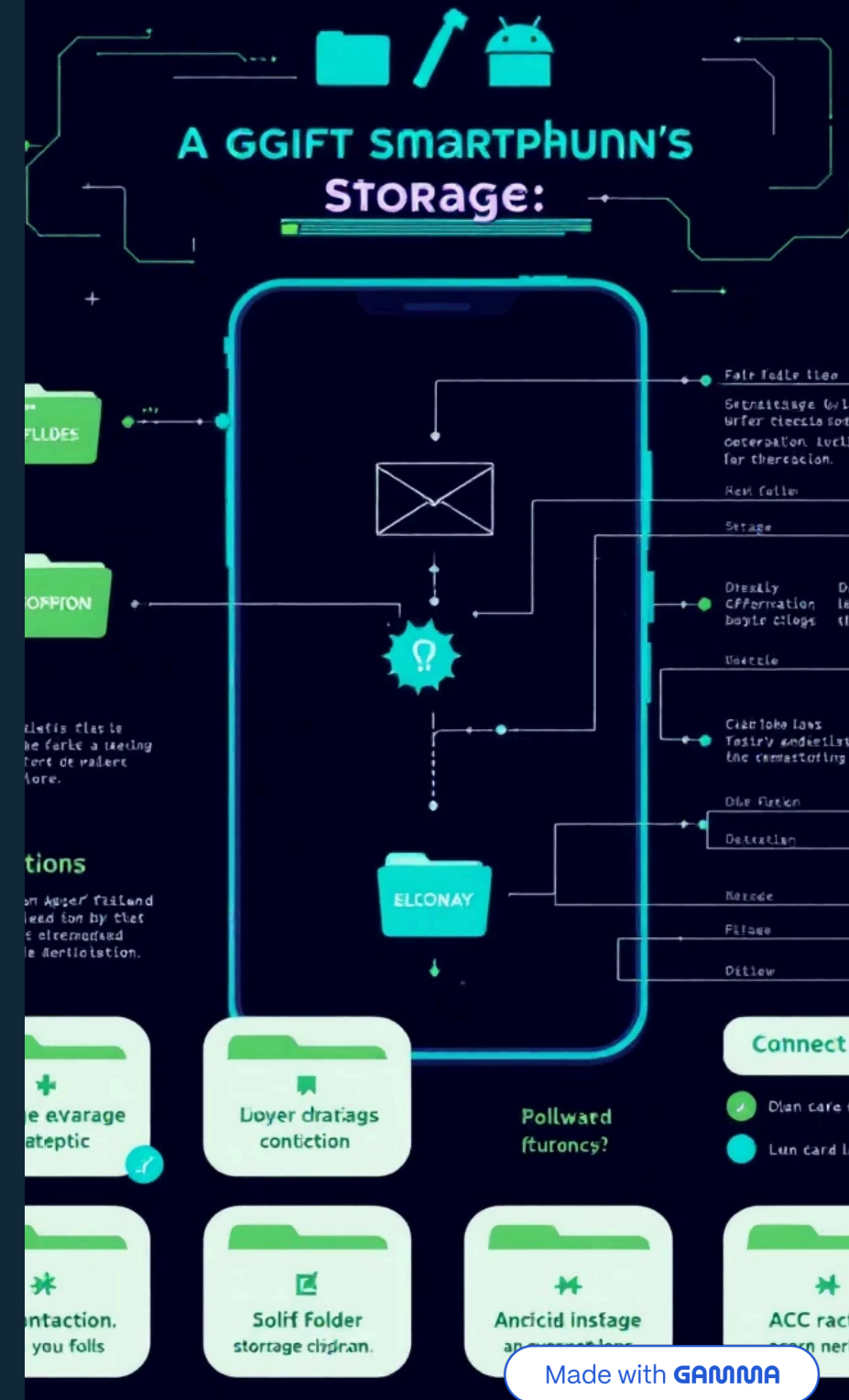
Almacenamiento Privado (Database & Keys)

Ruta: `/data/data/com.whatsapp/`

Contenido crítico:

- Archivo key (llave maestra de cifrado)
- Bases de datos SQLite sin cifrar
- Archivos WAL con mensajes en caché
- Logs de llamadas (wa.db)

Acceso exclusivo: Solo con privilegios Root



El Cifrado Crypt14 / Crypt15

WhatsApp implementa cifrado robusto en sus backups de la SDCard para proteger la información contra accesos no autorizados. Comprender este mecanismo es fundamental para la extracción forense efectiva.

01

Algoritmo de cifrado

Utiliza AES-256-GCM, uno de los estándares más seguros de la industria. Proporciona confidencialidad e integridad de los datos mediante autenticación de mensajes.

02

La llave maestra

El archivo "key" se genera automáticamente durante la instalación de la aplicación. Permanece almacenado exclusivamente en /data/data y nunca abandona esta ubicación protegida, a menos que se tengan privilegios Root.

03

Ventaja forense

Con acceso Root, podemos extraer directamente la base de datos "viva" (msgstore.db sin extensión .crypt) que la aplicación utiliza en tiempo real, evitando completamente el proceso de descifrado.

 **Forensic Fact:** El acceso Root nos permite copiar msgstore.db directamente desde la partición /data, obteniendo la base de datos en formato SQLite plano, lista para análisis inmediato sin necesidad de claves de descifrado.

DEMO 4: Escalada de Privilegios

La validación del acceso Root es el primer paso crítico antes de iniciar cualquier extracción forense. Este proceso confirma que tenemos los permisos necesarios para acceder a la partición de datos protegida del sistema.

Paso 1: Iniciar shell ADB

```
adb shell
```

Establece conexión con el dispositivo Android a través del Android Debug Bridge.

Paso 2: Solicitar privilegios Root

```
su
```

El prompt del sistema debe cambiar de \$ a #, indicando acceso superusuario exitoso.

Paso 3: Validar acceso a datos protegidos

```
ls -l /data/data/
```

Deberíamos visualizar el directorio `com.whatsapp` en la lista, confirmando acceso total a la partición de datos privados.

Paso 4: Salir del shell

```
exit  
exit
```

Doble exit: primero para abandonar el modo Root, segundo para cerrar el shell de ADB.

Localizando el Objetivo: msgstore.db

La navegación precisa dentro de la estructura de directorios protegidos es esencial para identificar los archivos críticos que contienen la evidencia digital. Cada archivo cumple una función específica en el ecosistema de WhatsApp.

Comando de exploración

```
adb shell "su -c 'ls -l  
/data/data/com.whatsapp/databases/'"
```

Este comando lista el contenido completo del directorio de bases de datos con permisos detallados y marcas temporales.

Archivos críticos a identificar



msgstore.db

Base de datos principal que contiene todos los chats actuales, mensajes de texto, metadatos de conversaciones y estructura de grupos.



wa.db

Almacena información de contactos sincronizados, números de teléfono asociados y datos de perfil de usuarios.



msgstore.db-wal

Write Ahead Log: contiene transacciones en caché aún no confirmadas en la DB principal. Puede incluir mensajes recientes o eliminados.

Extracción de la Llave Maestra

Aunque podamos extraer la base de datos en formato plano, la adquisición del archivo "key" es crucial para mantener la cadena de custodia forense y permitir el análisis de backups históricos cifrados que puedan existir en otros dispositivos o almacenamientos en la nube.

1

Copia temporal

```
adb shell "su -c 'cp  
/data/data/com.whatsapp/files/key  
/sdcard/'"
```

Copiamos el archivo key desde la zona protegida hacia la SDCard pública temporalmente.

2

Descarga a PC

```
adb pull /sdcard/key .
```

Extraemos el archivo key desde el dispositivo móvil hacia nuestro sistema de análisis forense.

3

Limpieza anti-forense

```
adb shell rm /sdcard/key
```

Eliminamos la copia temporal de la SDCard para no dejar rastros de nuestra actividad de extracción.

❏ **Nota técnica:** Esta es una técnica "sucia pero efectiva" que aprovecha la zona pública del dispositivo como puente de transferencia. En un escenario de investigación real, documentar cada paso es fundamental para la validez legal de la evidencia.

Extracción de Bases de Datos

Este es el paso crítico de exfiltración donde transferimos las bases de datos SQLite desde el dispositivo Android hacia nuestro sistema de análisis forense Windows. La precisión en esta etapa determina la integridad de toda la evidencia digital recolectada.

Fase 1: Copia a zona accesible

```
adb shell "su -c 'cp  
/data/data/com.whatsapp/databases/msgstore.db  
/sdcard/'"
```

```
adb shell "su -c 'cp  
/data/data/com.whatsapp/databases/wa.db /sdcard/'"
```

Copiamos ambas bases de datos desde la partición protegida /data hacia la SDCard pública, superando las restricciones de permisos de ADB.

Fase 2: Descarga a estación de trabajo

```
adb pull /sdcard/msgstore.db .
```

```
adb pull /sdcard/wa.db .
```

Extraemos los archivos de base de datos desde el dispositivo móvil hacia el directorio actual de nuestro sistema Windows, completando la adquisición forense.

Write Ahead Log (WAL) & Shared Memory



Concepto técnico

SQLite moderno implementa archivos temporales (.wal, .shm) para optimizar el rendimiento de escritura mediante transacciones diferidas. El modo WAL permite lecturas concurrentes mientras se realizan escrituras.

Importancia forense crítica

Los mensajes más recientes, o aquellos eliminados recientemente, pueden residir exclusivamente en el archivo WAL sin haberse consolidado aún en la base de datos principal. **Ignorar el WAL puede significar perder evidencia crucial.**

Acción requerida

Siempre extraer msgstore.db-wal si existe en el directorio de bases de datos. Utilizar el mismo procedimiento de copia y descarga empleado para msgstore.db principal.

```
adb shell "su -c 'cp /data/data/com.whatsapp/databases/msgstore.db-wal  
/sdcard/'"  
adb pull /sdcard/msgstore.db-wal .
```

Adquisición de Multimedia

El contexto visual completa la narrativa forense. Las fotografías, videos y archivos de audio proporcionan evidencia corroborativa esencial que complementa los datos textuales de las conversaciones. La carpeta "Sent" es particularmente valiosa como evidencia de exfiltración de información.

Ubicación de multimedia

Ruta completa:

```
/sdcard/Android/media/com.whatsapp/WhatsApp/Media/
```

Contiene subdirectorios organizados por tipo: WhatsApp_Images, WhatsApp_Video, WhatsApp_Audio, WhatsApp_Documents.

Carpeta Sent: Evidencia de envío

Comando de extracción selectiva:

```
adb pull  
/sdcard/Android/media/com.whatsapp/WhatsApp/Media/WhatsApp_Images/Sent .
```

Esta carpeta contiene únicamente las imágenes enviadas por el usuario del dispositivo, proporcionando evidencia directa de exfiltración o compartición de información sensible.

Resultado final: Ahora disponemos de una adquisición forense completa: bases de datos SQLite (msgstore.db, wa.db, archivos WAL), llave maestra de cifrado (key), y evidencia multimedia organizada. Todo listo para el análisis detallado en herramientas especializadas como DB Browser for SQLite o AXIOM.



Preparación del Entorno de Análisis Forense

Una vez completada la extracción exitosa de los archivos desde el dispositivo móvil, iniciamos la fase crítica del análisis forense. Los archivos clave, incluyendo msgstore.db y wa.db, ahora residen en nuestro entorno Windows controlado, listos para el análisis profundo mediante técnicas de threat hunting basadas en SQL.

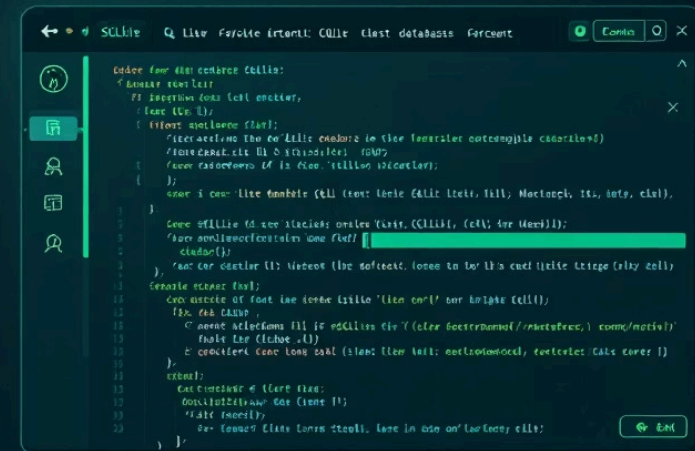
Configuración de Herramientas de Análisis

DB Browser for SQLite

Herramienta fundamental para la investigación forense de bases de datos móviles. Permite visualización completa de estructuras, ejecución de queries complejas y exportación de resultados.

Validación Crítica

Antes de proceder, verificar que msgstore.db tenga tamaño superior a 0 KB. Un archivo vacío o corrupto indica fallo en la extracción y requiere reinicio del proceso.



📌 **Próximo Paso:** Aplicar técnicas de Threat Hunting mediante queries SQL especializadas para identificar actividad maliciosa, exfiltración de datos y vectores de ataque.

Arquitectura de msgstore.db

La base de datos de WhatsApp utiliza una estructura relacional compleja que evolucionó significativamente en versiones recientes. Comprender esta arquitectura es fundamental para realizar análisis forense efectivo.



message / message_view

Tabla central conteniendo el cuerpo del mensaje, timestamp Unix en milisegundos, estado de entrega, tipo de mensaje y referencias a chat.



jid

Tabla de mapeo crítica que traduce IDs internos a números telefónicos reales. Esencial para identificación de participantes.



chat

Metadatos de conversaciones incluyendo nombre del chat, timestamp de creación, última actividad y referencias a participantes.

Concepto Clave: Los mensajes no almacenan números directamente. Utilizan IDs que deben cruzarse con la tabla jid mediante JOINs SQL para reconstruir la comunicación legible.

Query 1: Reconstrucción Cronológica de Comunicaciones

La primera técnica forense esencial es reconstruir el chat en formato human-readable, uniendo las tres tablas principales mediante LEFT JOINs para preservar todos los registros incluso con datos incompletos.

SQL Query Completo

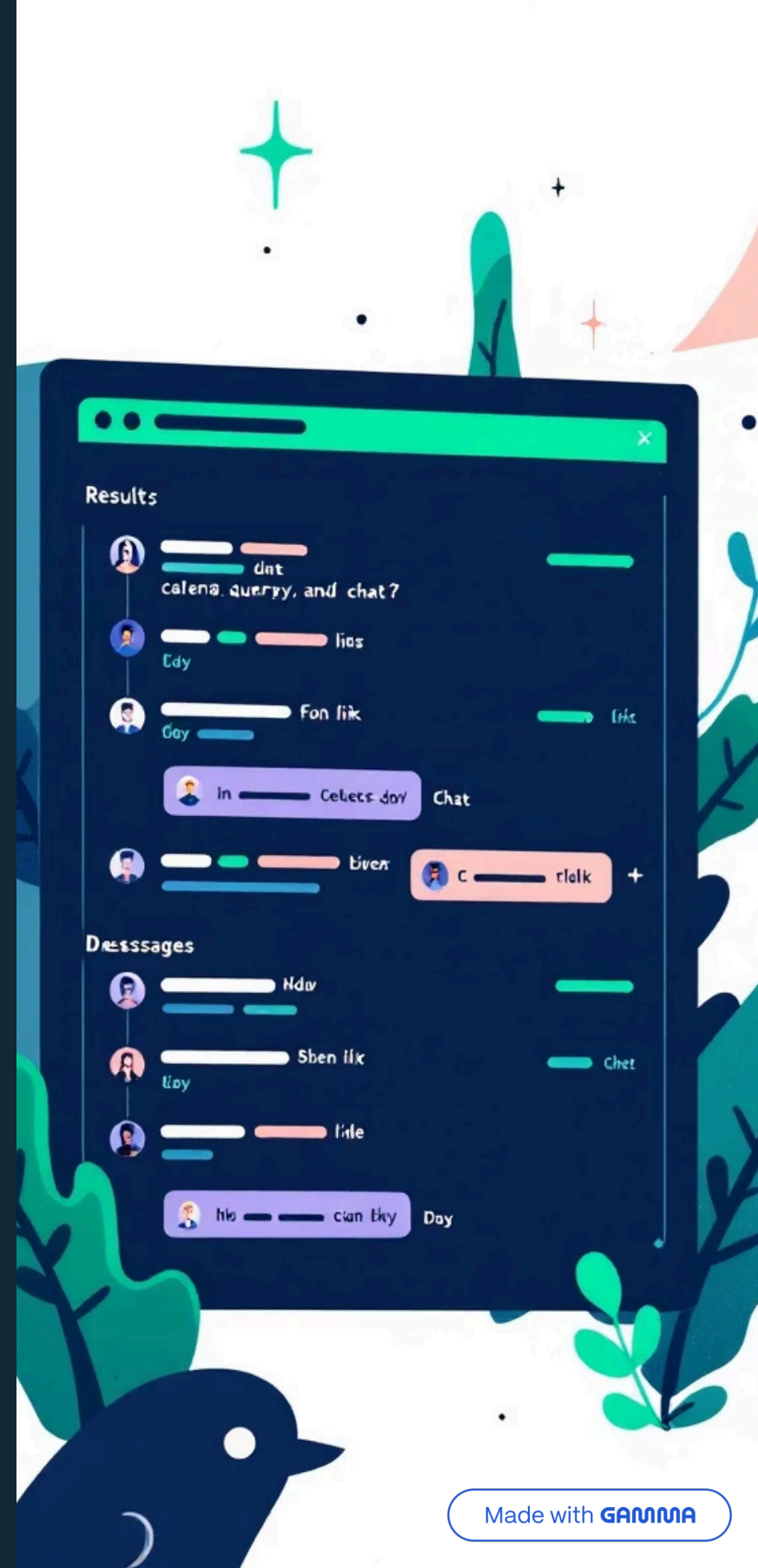
```
SELECT
  datetime(message.timestamp/1000, 'unixepoch') as Fecha,
  jid.user as Numero,
  message.text_data as Mensaje
FROM message
LEFT JOIN chat ON chat._id = message.chat_row_id
LEFT JOIN jid ON jid._id = chat.jid_row_id
ORDER BY message.timestamp DESC;
```

Elementos Críticos

- Conversión timestamp Unix a formato legible
- Mapeo de IDs a números reales
- Ordenamiento cronológico descendente
- Preservación de contexto conversacional

Aplicación Forense

Este query genera una línea temporal completa de comunicaciones, fundamental para establecer secuencia de eventos en investigaciones de incidentes de seguridad.



Query 2: Threat Hunting - Detección de Malware

Escenario de Incidente

Empleado comprometido recibiendo payload de infección a través de WhatsApp. Vectores comunes: archivos APK maliciosos, ejecutables Windows, scripts shell.



Query de Detección

```
SELECT *  
FROM message  
WHERE text_data LIKE '%.apk'  
OR text_data LIKE '%.exe'  
OR text_data LIKE '%.sh';
```

Patrones de Búsqueda

- **.apk:** Malware Android (trojanos bancarios, spyware)
- **.exe:** Malware Windows (ransomware, RATs)
- **.sh:** Scripts maliciosos Linux/Android

📄 **Acción Post-Detección:** Extraer archivo de carpeta Media, calcular hash SHA-256, consultar en VirusTotal y plataformas de Threat Intelligence.

Query 3: Investigación de Exfiltración de Datos

La fuga de información confidencial representa uno de los incidentes más críticos en respuesta a incidentes corporativos. WhatsApp es un vector común para exfiltración debido a su uso generalizado y percepción de privacidad.

Documentos Sensibles

Búsqueda de archivos PDF, Excel, Word que puedan contener información confidencial, financiera o estratégica de la organización.

Palabras Clave Críticas

Detección de términos como "confidencial", "password", "credential", "secreto", "interno" que indican contenido sensible.

Query SQL Especializado

```
SELECT
  datetime(timestamp/1000, 'unixepoch') as Fecha,
  text_data as Contenido
FROM message
WHERE text_data LIKE '%.pdf'
   OR text_data LIKE '%.xlsx'
   OR text_data LIKE '%confidencial%'
   OR text_data LIKE '%password%'
   OR text_data LIKE '%credencial%';
```

Los resultados permiten construir una línea temporal de exfiltración, identificar destinatarios y cuantificar el alcance del compromiso para el reporte ejecutivo.

Query 4: Extracción de IoCs de Red

Los enlaces maliciosos distribuidos vía WhatsApp constituyen vectores de ataque primarios en campañas de phishing, credential harvesting y distribución de malware. La extracción sistemática de URLs permite generar Indicadores de Compromiso (IoCs) accionables.

Query de Extracción

```
SELECT
  text_data,
  datetime(timestamp/1000,
    'unixepoch') as Fecha
FROM message
WHERE text_data LIKE 'http://%'
  OR text_data LIKE 'https://%';
```

Proceso de Respuesta

1. Extraer todos los dominios únicos
2. Consultar en bases de Threat Intelligence
3. Generar reglas de bloqueo para Firewall
4. Implementar en IDS/IPS corporativo
5. Actualizar EDR con IoCs confirmados

📌 **Defensa Proactiva:** Los dominios extraídos deben bloquearse inmediatamente en perímetro de red para prevenir propagación del ataque a otros usuarios de la organización.

Análisis Forense de wa.db y Generación de IoCs



Análisis de Contactos

La tabla wa_contacts revela la red de comunicaciones del sospechoso. Campos críticos: jid (número real), status (frase de estado potencialmente reveladora), y display_name.



Correlación de Inteligencia

Cruzar números desconocidos con bases de Threat Intelligence, OSINT y registros previos de incidentes para identificar actores maliciosos conocidos.



Generación de IoCs

Transformar evidencia en defensa accionable: Network IoCs (dominios), File IoCs (hashes SHA-256), Identity IoCs (números atacantes).

Los IoCs generados alimentan sistemas SIEM, EDR y Threat Intelligence platforms, creando capacidad de detección preventiva contra futuros ataques similares en toda la infraestructura.



Estrategias de Contención y Remediación

Ante confirmación de compromiso o exfiltración de datos, la respuesta debe ser inmediata, coordinada y basada en procedimientos de Incident Response establecidos.

O1

Revocación de Sesiones Activas

WhatsApp Web permite sesiones simultáneas en múltiples dispositivos. Cerrar todas las sesiones vinculadas desde el móvil para prevenir acceso remoto continuo del atacante.

O2

Mobile Device Management (MDM)

En dispositivos corporativos, ejecutar remote wipe mediante MDM para eliminar toda información sensible. Documentar acción en cadena de custodia antes de borrado.

O3

Aislamiento de Red

Bloquear dirección MAC del dispositivo comprometido en infraestructura WiFi corporativa. Implementar reglas en NAC (Network Access Control) para prevenir reconexión.

O4

Análisis Post-Mortem

Realizar análisis forense completo del dispositivo antes de restauración. Documentar vectores de ataque, datos comprometidos y lecciones aprendidas para actualización de políticas.

Informe Forense y Desafío Final

Estructura del Informe Forense Móvil

1 Resumen Ejecutivo

Descripción concisa del incidente, impacto de negocio y hallazgos críticos para audiencia no técnica.

2 Metodología Técnica

Detalle de herramientas utilizadas: ADB Root, extracción file system, DB Browser for SQLite, queries SQL específicos ejecutados.

3 Evidencia Digital

Screenshots de chats reconstructivos, archivos exfiltrados identificados, timestamps precisos con zona horaria.

4 Cadena de Custodia

Hash SHA-256 de msgstore.db original, registro de accesos, transferencias de evidencia y almacenamiento forense.



Conclusión Clave: El dispositivo móvil no es una caja negra impenetrable. Con ADB y SQL, se convierte en una fuente abierta y valiosa de inteligencia forense digital.

Desafío Práctico

Descarguen su propio backup de WhatsApp, ejecuten un query buscando cuántas veces escribieron la palabra "password" en sus chats, y reflexionen sobre higiene de seguridad digital personal.

¿Preguntas?